



密码协议概述

汪 定

南开大学 密码网络空间安全学院

2026年3月5日



提 纲

CONTENTS



1. 密码协议概述

2. 两个密码协议实例

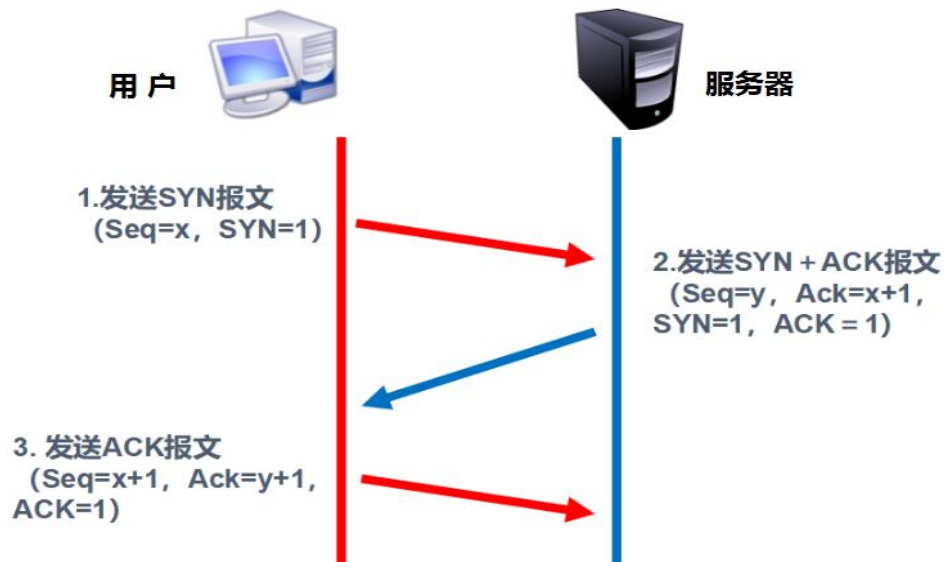
什么是协议（1）

□ 基本概念

两个或两个以上的参与者为完成某项特定任务而采取的一系列步骤。

□ 三层含义

- 协议是有序的过程，每一步必须依次执行
- 协议至少需要两个参与者
- 通过执行协议必须能够完成某项任务



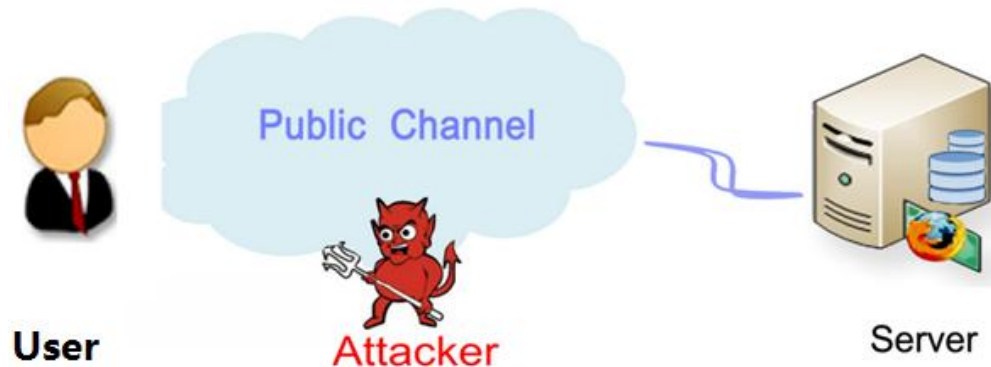
什么是协议（2）

- **定义：**两个或两个以上的参与者为完成某项特定任务而采取的一系列步骤。
- **特点**
 - 协议的参与方必须了解协议，明确协议执行的所有步骤
 - 协议的参与方都承诺按协议步骤执行协议
 - 协议必须清楚、完整，对每种可能的情况必须规定明确、具体的动作
- **基本要求**
 - **正确性**（能达成预定的功能、目标）
 - **高效性**（计算、通信、存储代价低）
- **特定情景下的要求**
 - 公平性（参加协议的各方在协议执行的任何阶段都处于平等地位）
 - 匿名性（不泄露协议参与方的身份）
 - 确定性、适时中止性、可追究性等等。。。。

什么是安全协议

□ 安全协议（密码协议）

- 具有安全功能的协议——安全协议
- 安全协议的设计必须采用密码技术——**密码协议**
- 具体意义：安全协议是建立在密码体制基础上的一种交互通信的协议，它运行在计算机通信网或分布式系统中，借助于密码算法来达到安全功能。



□ **密码技术：**随机数生成、加密/解密算法、Hash函数、数字签名等

□ **安全功能：**密钥交换、密钥分配、消息鉴别、身份认证

□ **应用系统：**电子选举、电子拍卖、公平电子交易等。

密码协议的分类

■ 按协议执行的轮数分

- ◆ 1轮协议
- ◆ 2轮协议
- ◆ 3轮协议
- ◆,
- ◆ n 轮协议

■ 按协议功能分

- ◆ 身份认证协议
- ◆ 密钥分配协议
- ◆ 密钥协商协议
- ◆ 秘密共享协议
- ◆ 访问控制协议
- ◆ 信息查询协议
- ◆ 计算外包协议
- ◆ 隐私计算协议
- ◆ 不经意传输协议
- ◆ 电子选举协议
- ◆

密码协议的分类（2）

■ 按协议应用目标分

- ◆ 选举协议
- ◆ 拍卖协议
- ◆ 支付协议
- ◆

■ 按协议的交互性分

- ◆ 交互协议
- ◆ 非交互协议

■ 按协议第三方性质分

- ◆ 仲裁协议
- ◆ 裁决协议
- ◆ 自动执行协议
- ◆

密码协议的安全性质

□ 安全协议的安全性质

- 认证性
- 机密性
- 完整性
- 不可否认性

□ 信息系统的安全性质

- ◆ 机密性
- ◆ 完整性
- ◆ 可用性
- ◆ 可控性
- ◆ 不可否认性

认证性的实现

- 目的：确保协议参与方为意定的实体。
- 一般通过直接或间接共享秘密实现：
 - 声称者使用仅为其与验证者知道的密钥封装消息，如果验证者能够成功地解密消息或验证封装是正确的，则证毕。
 - 声称者使用私钥对消息签名，验证者使用声称者的公钥验证签名，如正确，证毕。
 - 声称者通过可信第三方来证明自己。

用途：对抗假冒攻击，确保身份的真实性，从而获取对某人或某事的信任。

机密性的实现

- 应用：保护协议消息不被非授权访问，防范窃听。
- 常用方法：对称加密 和 公钥加密。
 - 对称加密算法：AES, DES; SM1、SM4、SM7
 - 非对称加密算法：RSA, ElGama; SM2, SM9

完整性的实现

- 应用：保护协议消息不被非法篡改、删除和替代。
- 常用方法：HMAC 和 数字签名。
 - HMAC: $H_k(M)$; 如 MD5、SHA1、SHA2、SHA3; SM3
 - $\text{Sig}_k(M)$

不可否认性的实现

- 目的：通过通信主体提供对方参与协议交换的证据，来保证其合法权益不受侵害。
 - 收集证据，以便事后能够向可信仲裁证明对方主体的确发送或接收了消息。
 - 证据实现：签名消息的形式。
 - 协议特点：证据的正确性，交易的公平性。
- 次要性质：适时中止性、可追究性等。

密码协议的系统模型



密码协议的攻击者模型



□ Dolev Yao模型

代表一个可以窃听、拦截和合成任何消息的攻击者，并且仅受所使用的加密方法的约束的限制。

□ Dolev Yao模型下攻击者能力

- 获取通过网络传递的任何消息
- 作为网络的合法用户（即可以发起与任何其他用户的对话）
- 可以成为任何发送者的接收者
- 可以通过冒充任何实体向其他任何实体发送消息。



可以认为：任何通过网络发送的消息都是攻击者发送的；任何接收到的任何消息“可能”都被攻击者操纵了。

密码协议的攻击者模型（2）

□ Dolev-Yao模型

代表一个可以监听、拦截和插入、伪造任何消息的攻击者，并且仅受所使用的加密方法的约束的限制。

□ Dolev Yao模型下攻击者不具有的能力

- 无法猜出从足够大的空间中选取的随机数
- 如果没有密钥，攻击者不能从密文中恢复出明文，也不能从明文构造出正确的密文
- 无法求解与公钥相匹配的私钥
- 无法控制计算环境私有区域，如合法用户的“内存”

注：这是一个强大而现实的攻击者。

三个密码协议设计原则

□ 第六感原则

不要假设你收到的消息有任何特定格式，除非你能明确地检查。

□ 明确原则

不要有任何模糊（隐性假设）和想当然（未意识到的假设）。

□ 极限攻击者原则

好的协议应该假设攻击者是强大的：唯一不给它的是使它能轻易攻破任何此类协议的能力。

密码协议的攻击目标

□ 协议使用的密码算法

加解密算法，hash函数，数字签名等等。

□ 协议本身

● 被动攻击

攻击者仅侦听协议交互的消息，然后加以利用。

● 主动攻击

攻击者可以侦听、插入、删除、
阻止协议交互的任何消息，
然后加以利用。

□ 协议的实现

如侧信道攻击。



密码协议的攻击手段

- 对安全协议的常见攻击手段

- ◆ 重放攻击
- ◆ 中间人攻击
- ◆ 并行会话攻击
- ◆ 反射攻击
- ◆ 拒绝服务攻击
- ◆ 密码服务滥用攻击
- ◆ 降级攻击
- ◆ 口令猜测攻击
- ◆ 未知密钥共享攻击
- ◆ 密钥泄露仿冒攻击
- ◆ 密钥重用攻击
- ◆ 。 。 。

基于口令的密钥协商协议-SPEKE

□ SPEKE协议

□ 1996年，由D. P.

Jablon提出，首次

发表于SIGCOMM

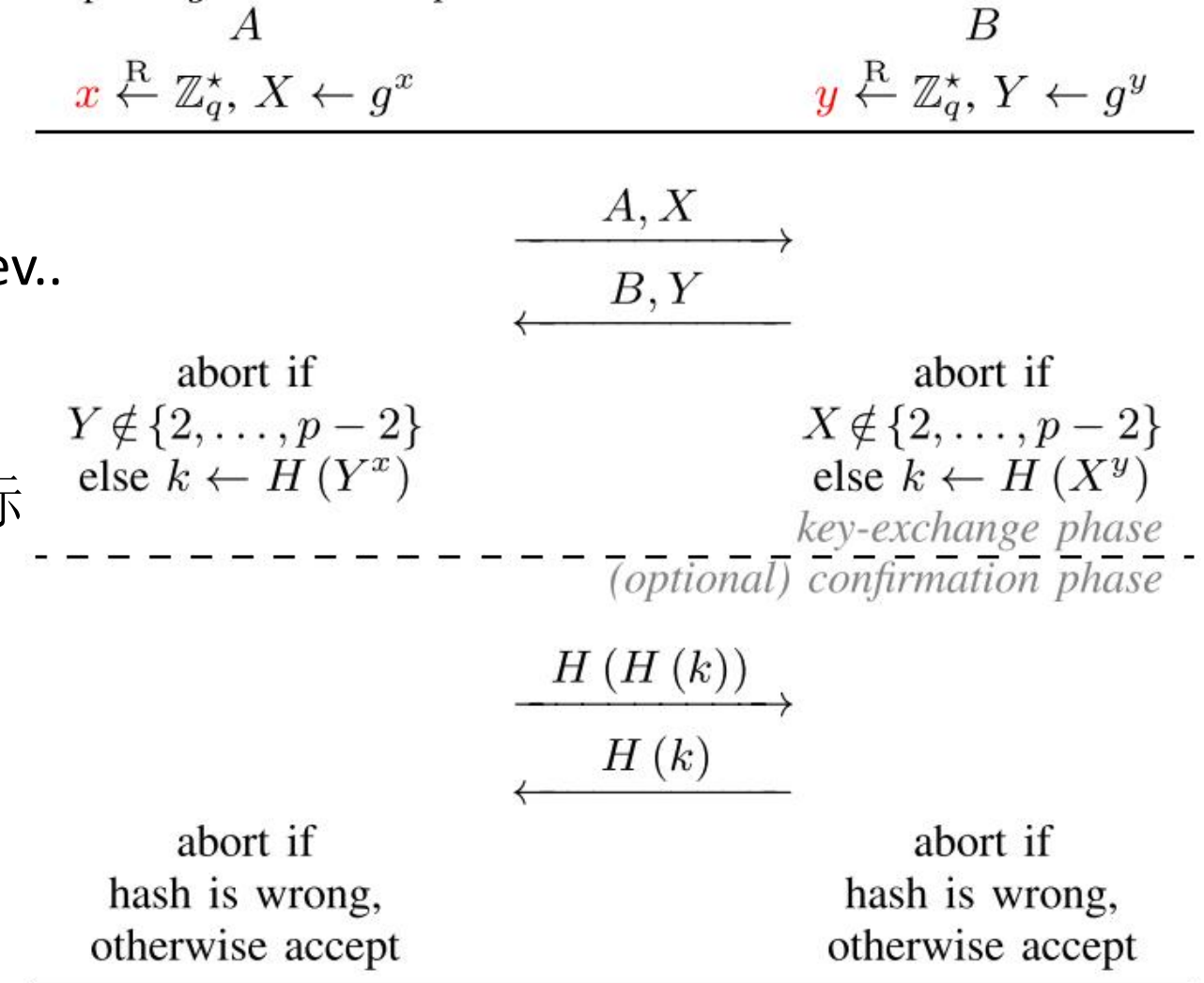
Comput. Commun. Rev..

□ 2006年，成为国际

标准IEEE P1363.2，

ISO/IEC 11770-4。

Figure 1. Original SPEKE scheme. A and B share the password s and computed $g = s^2 \bmod p$.



针对SPEKE的攻击：平行会话攻击

Alice

$$x \xleftarrow{R} \mathbb{Z}_q^*, X \leftarrow g^x$$

$$k \leftarrow \text{KDF}(Y^z \cdot x)$$

Start key confirmation

Verify key confirmation

$$y \xleftarrow{R} \mathbb{Z}_q^*, Y \leftarrow g^y$$

$$k \leftarrow \text{KDF}(X^z \cdot y)$$

Verify key confirmation

Reply key confirmation

Bob(Eva)

$$1. (A, X) \xrightarrow{\hspace{1cm}}$$

$$4. (B, Y^z) \xleftarrow{\hspace{1cm}}$$

$$5. H(H(k)) \xleftarrow{\hspace{1cm}}$$

$$8. H(k) \xleftarrow{\hspace{1cm}}$$

Choose arbitrary z (Session 1)

$$\{X^z, H(H(k))\} \downarrow \uparrow \{Y^z, H(k)\}$$

$$2. (B, X^z) \xleftarrow{\hspace{1cm}}$$

$$3. (A, Y) \xrightarrow{\hspace{1cm}}$$

$$6. H(H(k)) \xleftarrow{\hspace{1cm}}$$

$$7. H(k) \xrightarrow{\hspace{1cm}}$$

(Session 2)

- 平行会话攻击：Eva仿冒Bob, 同时与Alice进行两个会话，利用消息顺序的差异，来得利
- 问题：该攻击是一个彻底成功的攻击吗？



提 纲

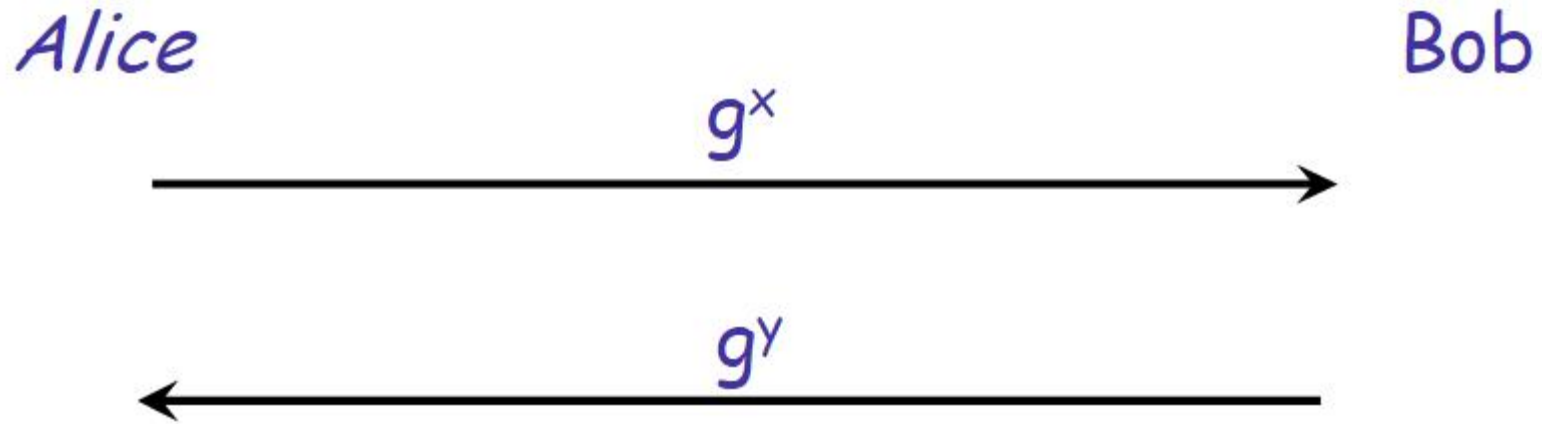
CONTENTS



1. 密码协议概述

2. 两个密码协议实例

Diffie-Hellman密钥交换

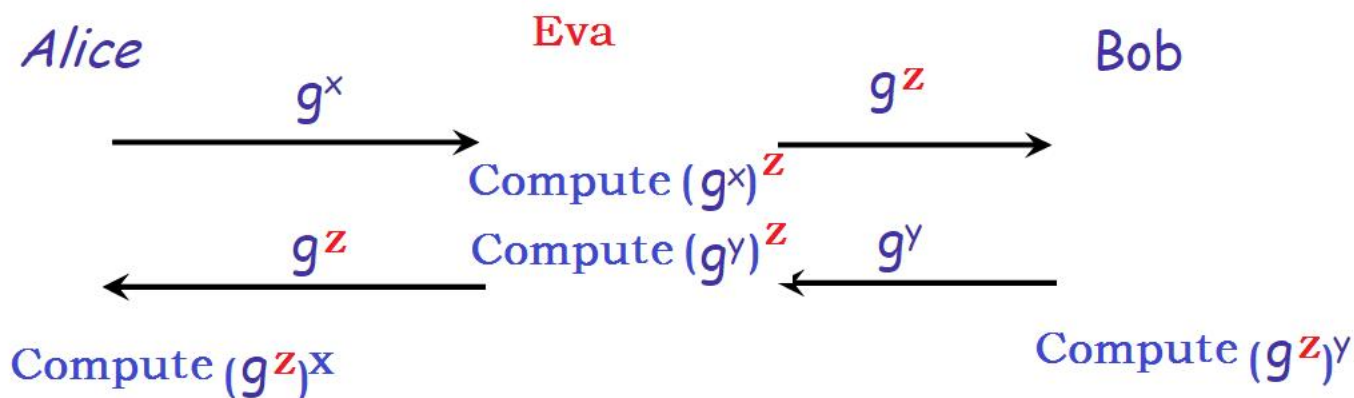


- both parties compute the secret key $K = g^{xy} = (g^x)^y = (g^y)^x$
- assumes authenticated channels (+ DDH assumption)
- open to m-i-t-m in a realistic unauthenticated setting

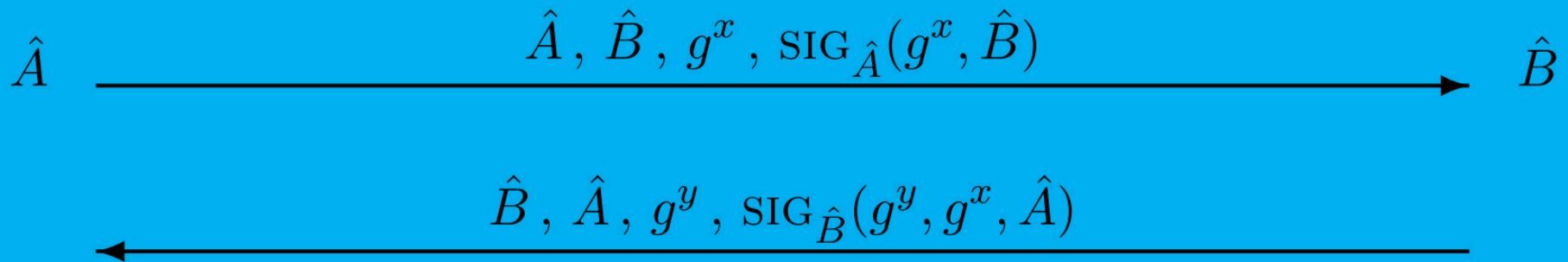
对Diffie-Hellman密钥交换的攻击

□著名的中间人攻击 (Man-in-the-Middle, MITM)

- 1) 收到来自Alice的 g^x 后, 中间人Eva可向Bob仿冒Alice;
- 2) 收到来自Bob的 g^y 后, 中间人Eva可向Alice仿冒Bob;
- 3) Eva可正确计算两个会话密钥 g^{xz} 和 g^{yz} .



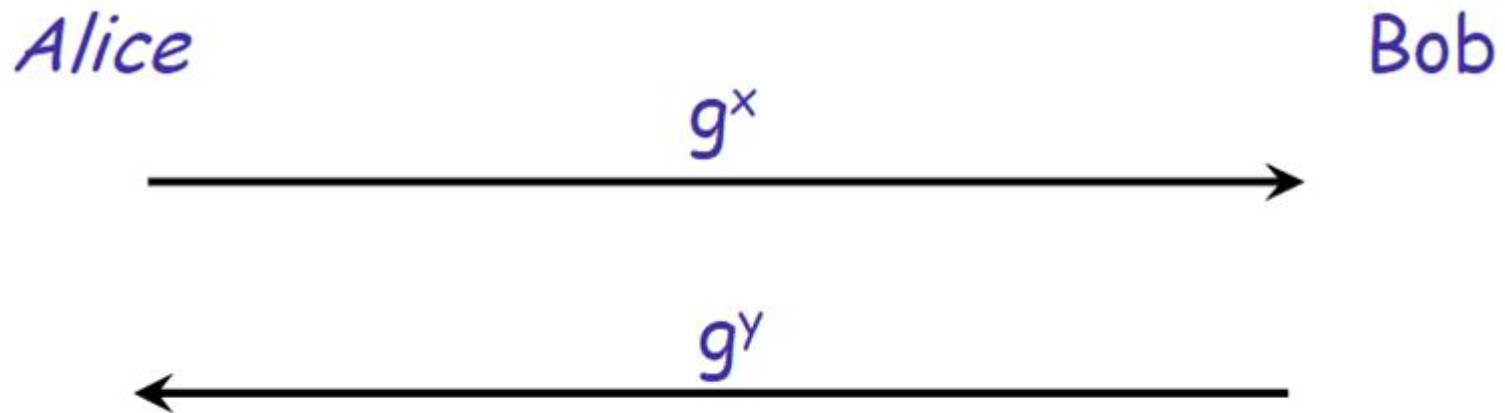
解决方案：通过显式认证（增加双方的签名）



- both parties compute the secret key $K = g^{xy} = (g^x)^y = (g^y)^x$

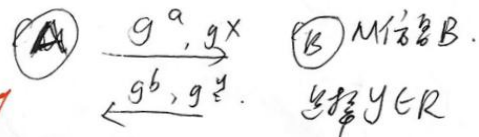
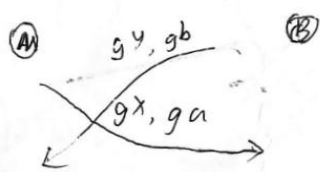
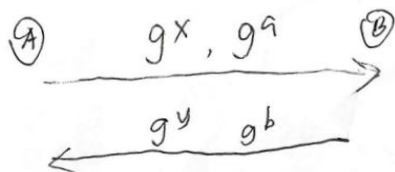
- 存在的一个明显的缺陷：一旦某一次会话的临时秘密 x 泄露，攻击者此后能始终仿冒 A 。
- 这违反一个基本原则：某个会话的安全性不应影响其它会话的安全性。

解决方案：通过隐式认证（计算会话密钥）



- As basic DH ($X=g^x, Y=g^y$), PKs: $A=g^a, B=g^b$
- Session key $K = ?$

会话密钥的6种计算方式



之后可以计算 g^{xy} (方法1, 2)

分析 -

$$\text{key}_1 = h(g^{ab}, g^{xy});$$

$$\text{key}_2 = h(g^{ab}, g^{xy}, g^x, g^y);$$

$$\text{key}_3 = g^{(x+a)(y+b)} = (AX)^{b+y} = (BY)^{a+x}$$

$$\text{key}_4 = g^{(x+ad)(y+be)}$$

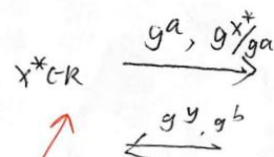
其中 d, e 是常数, 防止被攻击
信息有泄露; $g^x, g^{x*/gad}$

$$\text{key}_5 = g^{(x+ad)(y+be)}$$

$$\text{但 } d = 2^l + (x \bmod 2^l)$$

$$e = 2^l + (y \bmod 2^l), \quad l = \frac{\log 2}{2};$$

则可抵抗方法3, 4的中间人攻击;



$$\text{key} = (XA)^{b+y}$$

$$= (g^{x*})^{b+y}$$

$$= (BY)^{x*}$$

这是A所能计算的
因为 x^* 是A的
秘密;

Key_6 即 HMQV的计算方式

如群 G 的 $\frac{q-1}{2}$ least significant
bits 是定值, 信息在方法3, 4
泄露;
Katz's 10. 11 如果在其自己名下注册AC公钥

MQV: 不安全的Diffie-Hellman密钥交换

□ UKS攻击

$$\hat{A} \quad A = g^a$$

$$\hat{A}, X = g^x \rightarrow$$

$$K_{AB} = (YB^e)^{x+da}$$

$$\hat{C} \quad C =$$

$$z \in_R \mathbb{Z}_2;$$

$$Z = XA^d$$

$$c = f^{-1} z \bmod 2;$$

$$C = g^c;$$

$$\hat{C}, Z = XA^d g^{-z} \rightarrow$$

$$\hat{B}, Y = g^y \leftarrow$$

其中, d, e, f 都是公开可计算的:

$$d = 2^l + (X \bmod 2^l); \quad // l = \frac{|Q|}{2}$$

$$e = 2^l + (Y \bmod 2^l);$$

$$f = 2^l + (z \bmod 2^l);$$

Alice

Bob

$$g^x$$

$$g^y$$

$$y \in_R \mathbb{Z}_2;$$

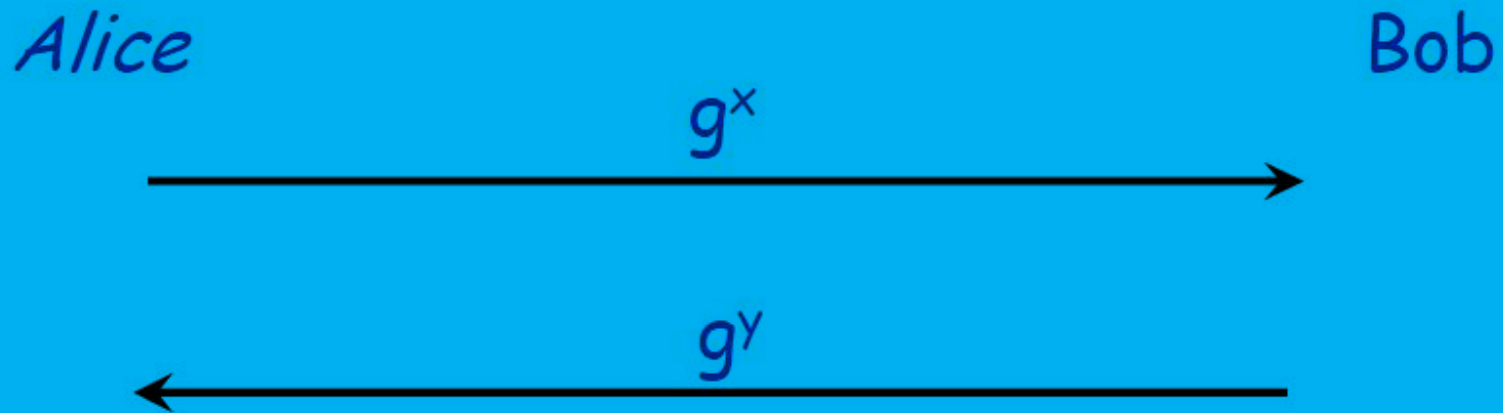
$$Y = g^y;$$

$$K_{CB} = (Z \cdot C^f)^{y+eb}$$

$$= (XA^d g^{-z} \cdot g^{f^{-1} \cdot z \cdot f})^{y+eb}$$

$$= (XA^d)^{y+eb}$$

HMQV: 安全的Diffie-Hellman密钥交换



- As basic DH ($X=g^x, Y=g^y$), PKs: $A=g^a, B=g^b$
- Both compute $\sigma=g^{(x+da)(y+eb)}$ as $\sigma = (YB^e)^{x+da} = (XA^d)^{y+eb}$
- $d=H(X, \text{"Bob"})$ $e=H(Y, \text{"Alice"})$ (here H outputs $|q|/2$ bits)
- Session key $K=H(\sigma)$



提 纲

CONTENTS



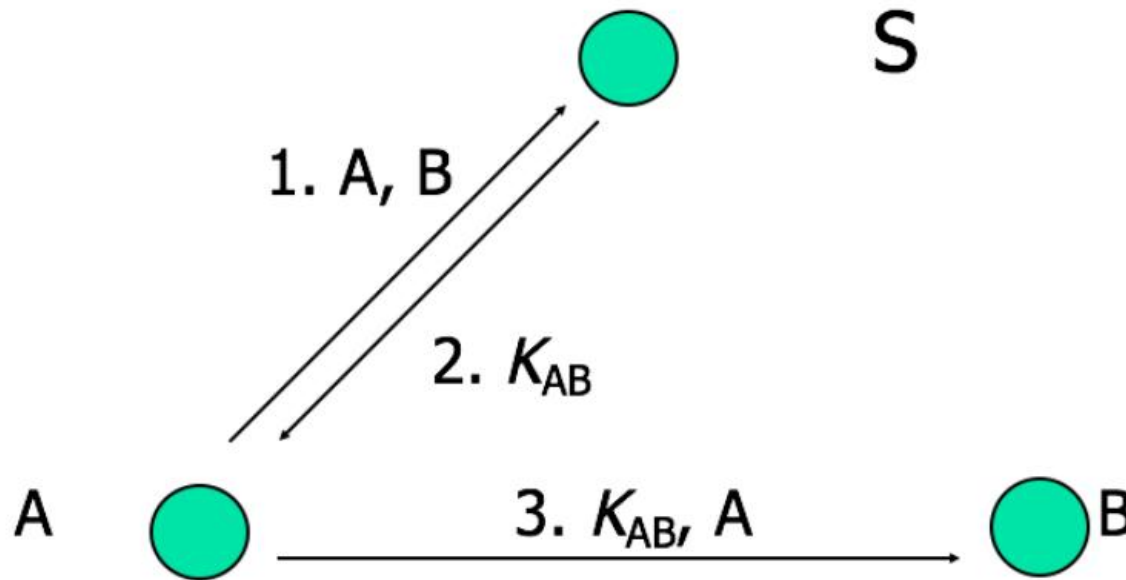
1. 密码协议概述

2. 两个密码协议实例

2.1 DH密钥交接协议

2.2 NS对称密钥认证协议

Needham-Schroeder对称密钥认证协议_v0



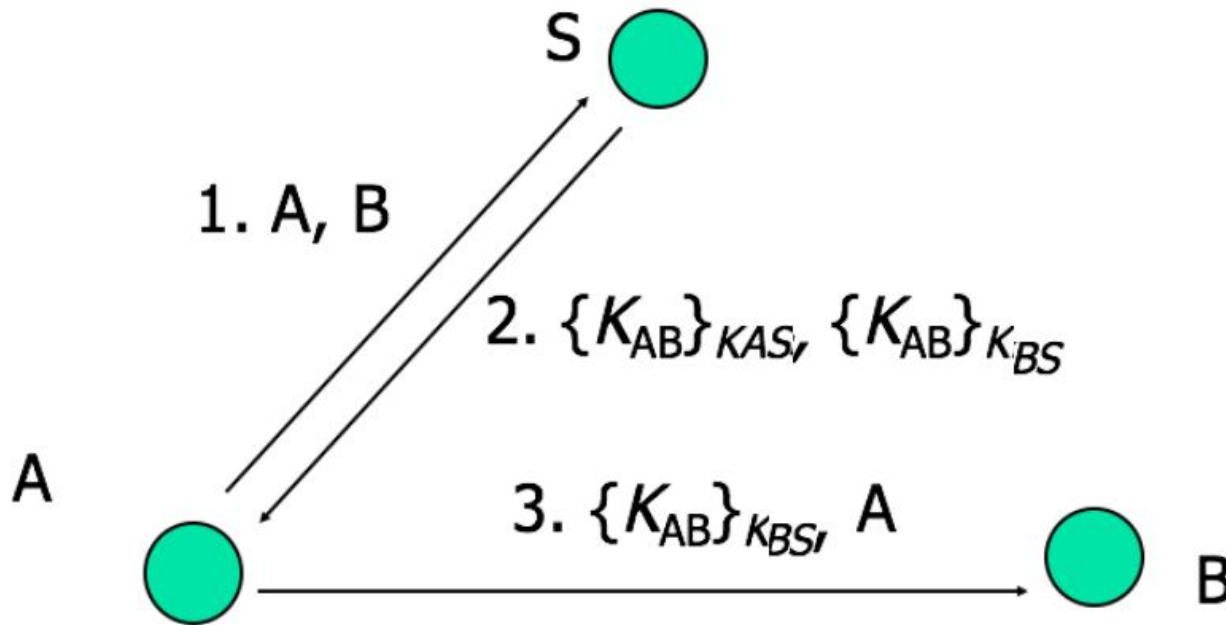
❑ 明显安全问题

一切传输皆明文，攻击者可窃听，伪造，中间人攻击。

1. $A \longrightarrow S: A, B$
2. $S \longrightarrow A: K_{AB}$
3. $A \longrightarrow B: K_{AB}, A$

Needham-Schroeder对称密钥认证协议_v1

□改进策略：对消息进行加密。

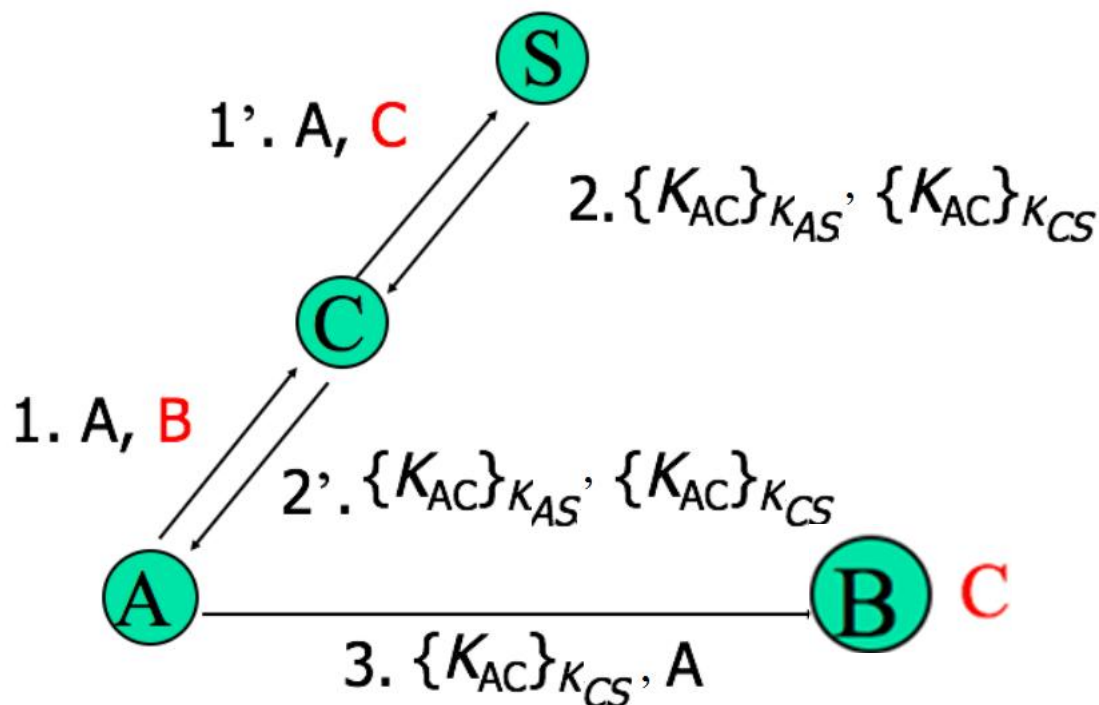


对NS_v1协议的攻击

中间人攻击

攻击者C的行动：1) 仿冒S与A通信；2) 仿冒A与S通信

攻击结果：A认为与B通信，实际上却与C通信（因为C成功获得了与A会话的会话密钥 K_{AC} ）。

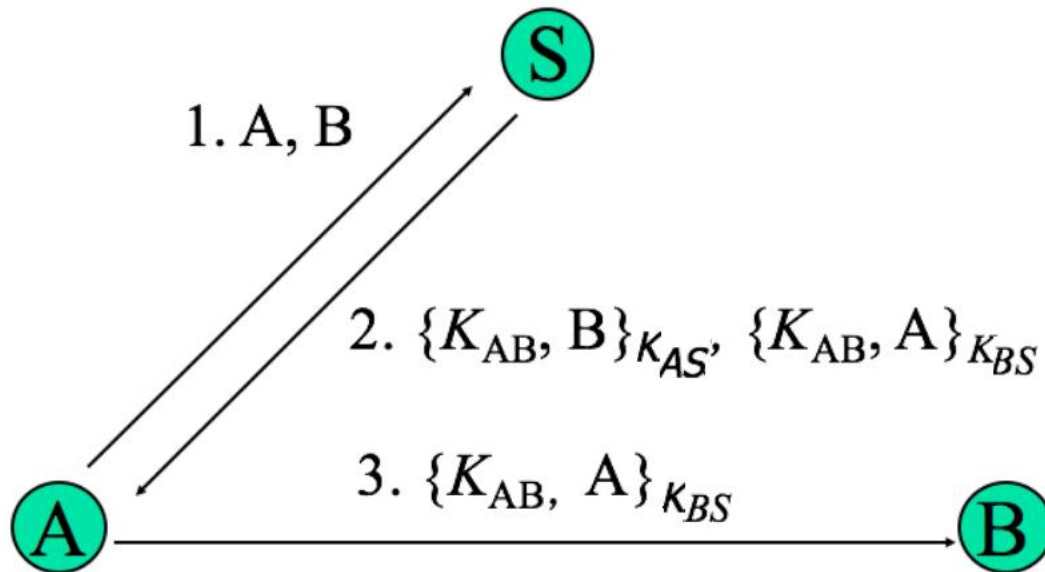


Needham-Schroeder对称密钥认证协议_v2

□改进策略：让A知道自己和谁在通信。

因此，服务器S在反馈时加入了通信对象：

- 1) S在给A的信息中，加入了意定的通信对象B
- 2) S在给B的信息中，加入了意定的通信对象A

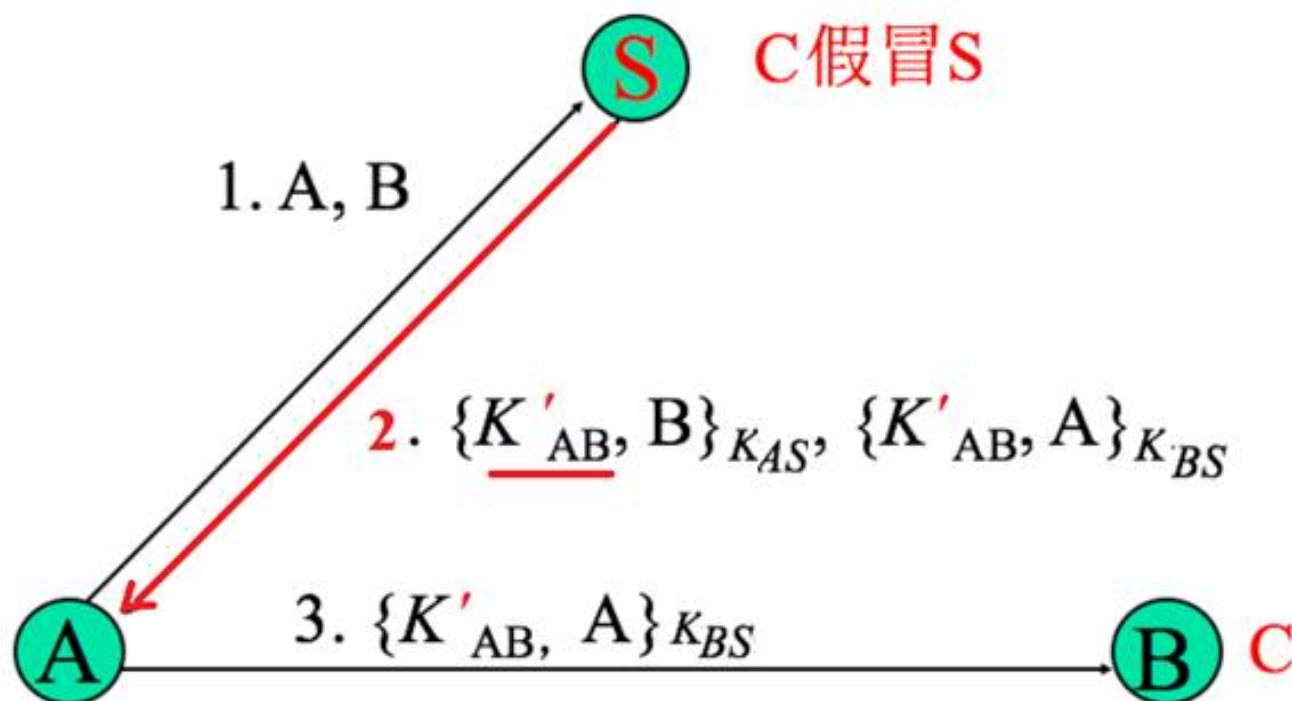


对NS_v2协议的攻击

□ 重放攻击

攻击者C的行动：重放S→A的某个旧消息。

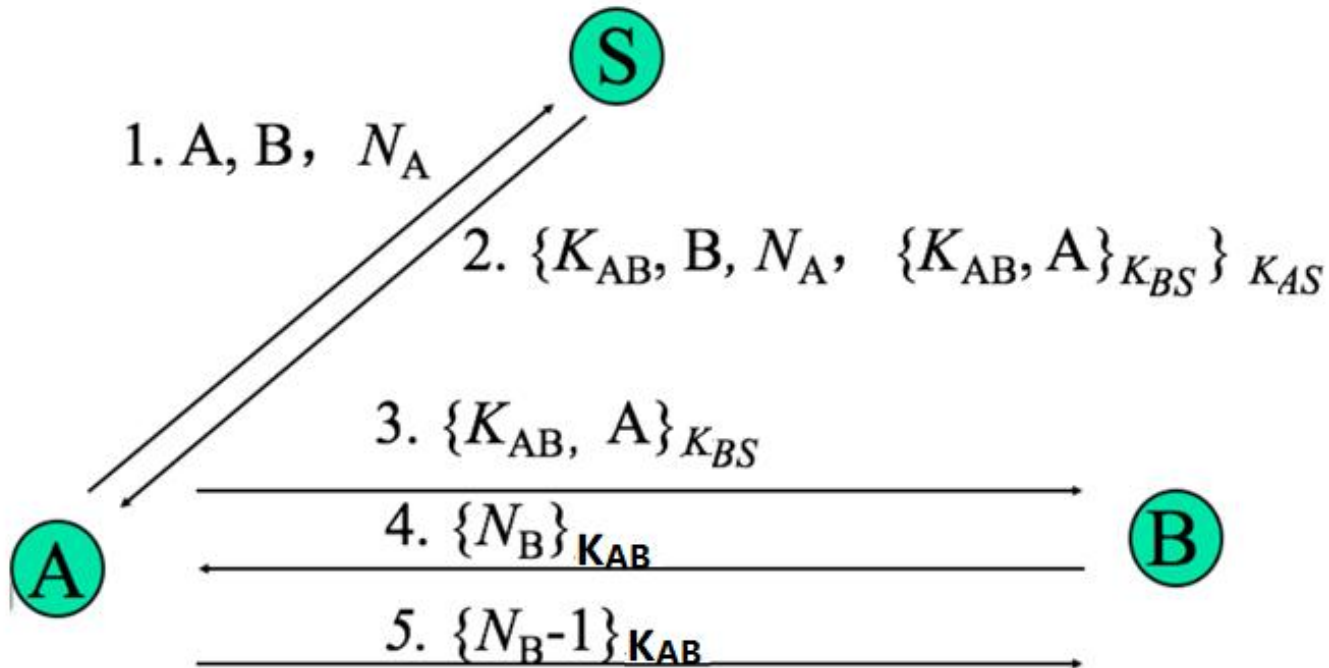
攻击结果： S认为与A通信，实际上却与C通信（因为旧消息中的会话密钥 K'_{AB} 可能已被C获得）。



Needham-Schroeder对称密钥认证协议_v3

□改进策略：加入挑战响应机制。

- 1) 在A与S的会话中，加入了随机数 N_A ;
- 2) 在A与B的会话中，加入了随机数 N_B ;

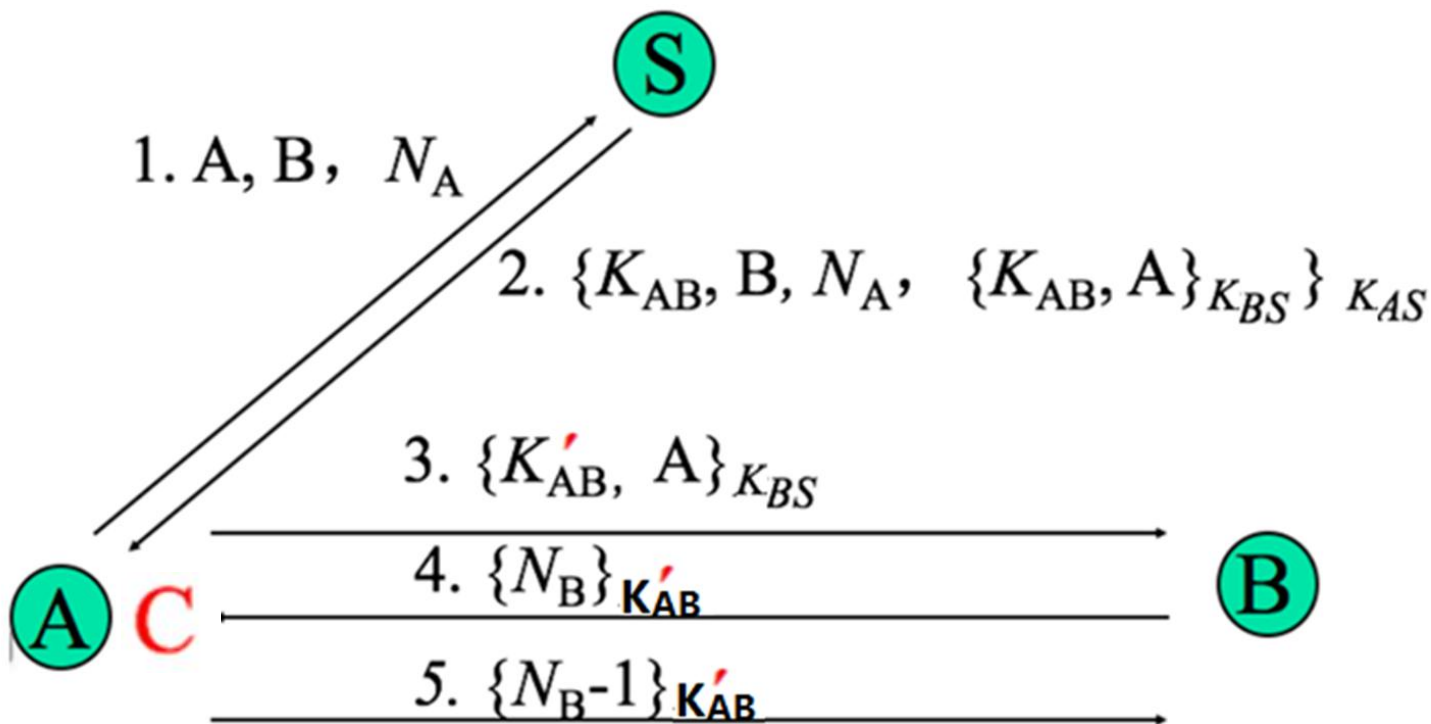


对NS_v3协议的攻击

□ 重放攻击

攻击者C的行动：重放A→B的某个旧消息。

攻击结果： B认为与A通信，实际上却与C通信（因为旧消息中的会话密钥 K'_{AB} 可能已被C获得）。

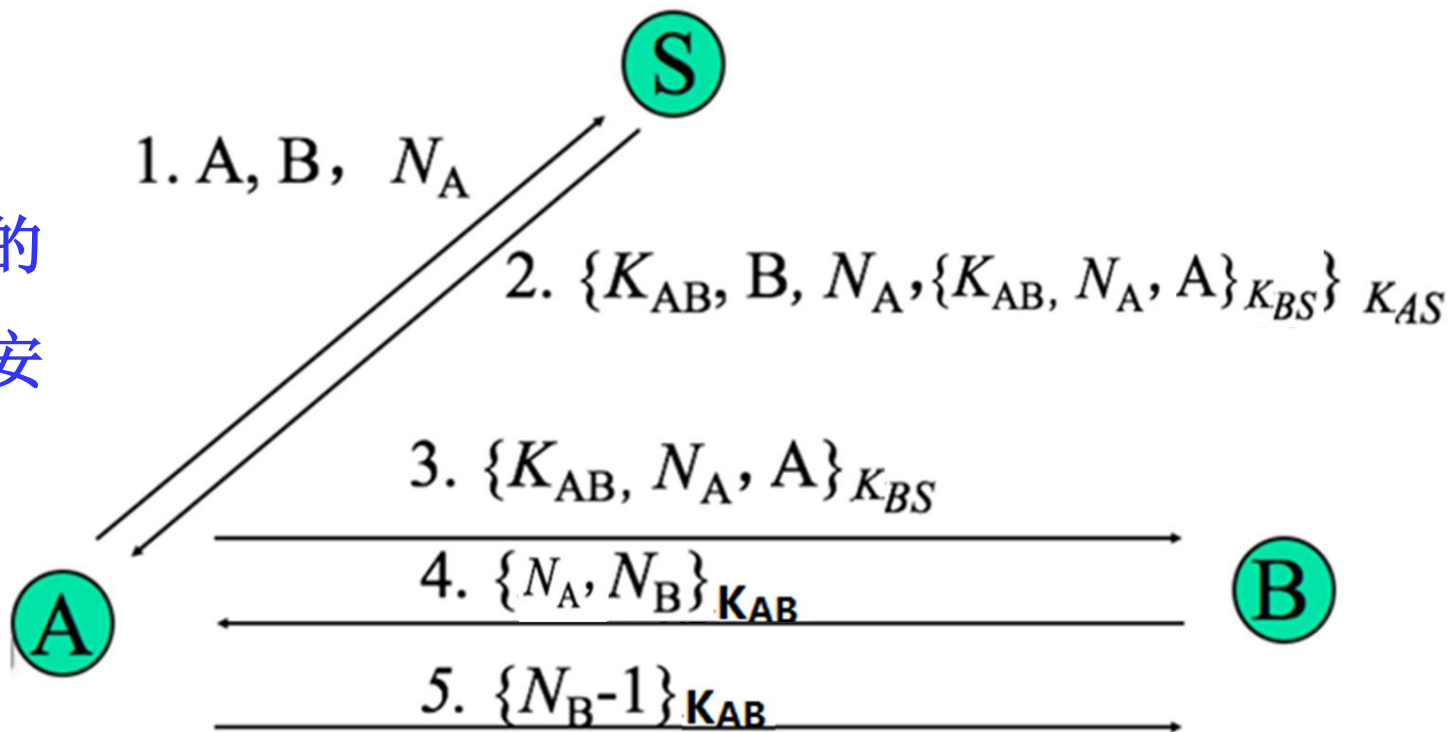


Needham-Schroeder对称密钥认证协议_v4

□改进策略：加入挑战响应机制。

- 1) 在A与S的会话中，发给B的密文中也加入了随机数 N_A ；
- 2) 在A与B的会话第一、二条消息中，也加入了随机数 N_A ；

这个改进的
V4版本就安
全了吗？

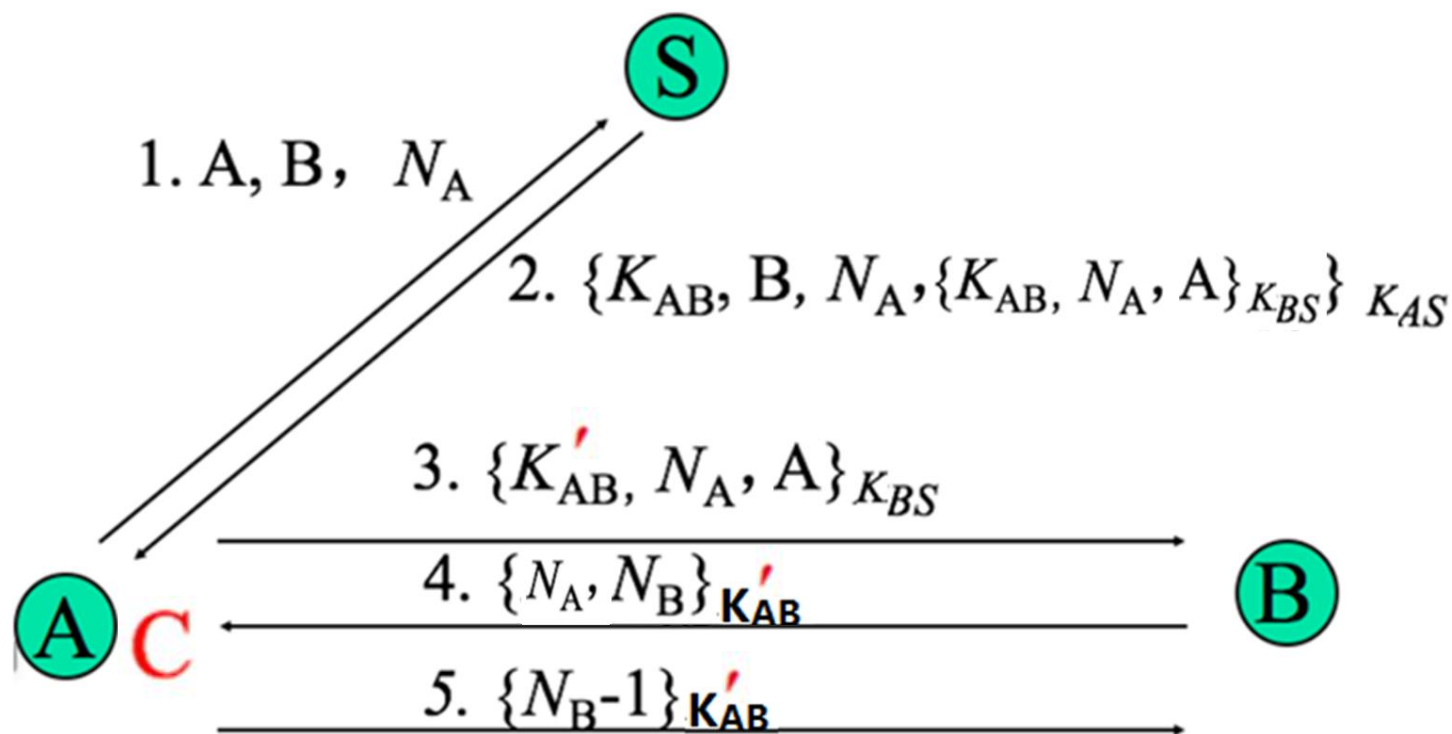


对NS_v4协议的攻击

□ 重放攻击

攻击者C的行动：重放A→B的某个旧消息。

攻击结果： B认为与A通信，实际上却与C通信（因为旧消息中的会话密钥 K'_{AB} 可能已被C获得）。

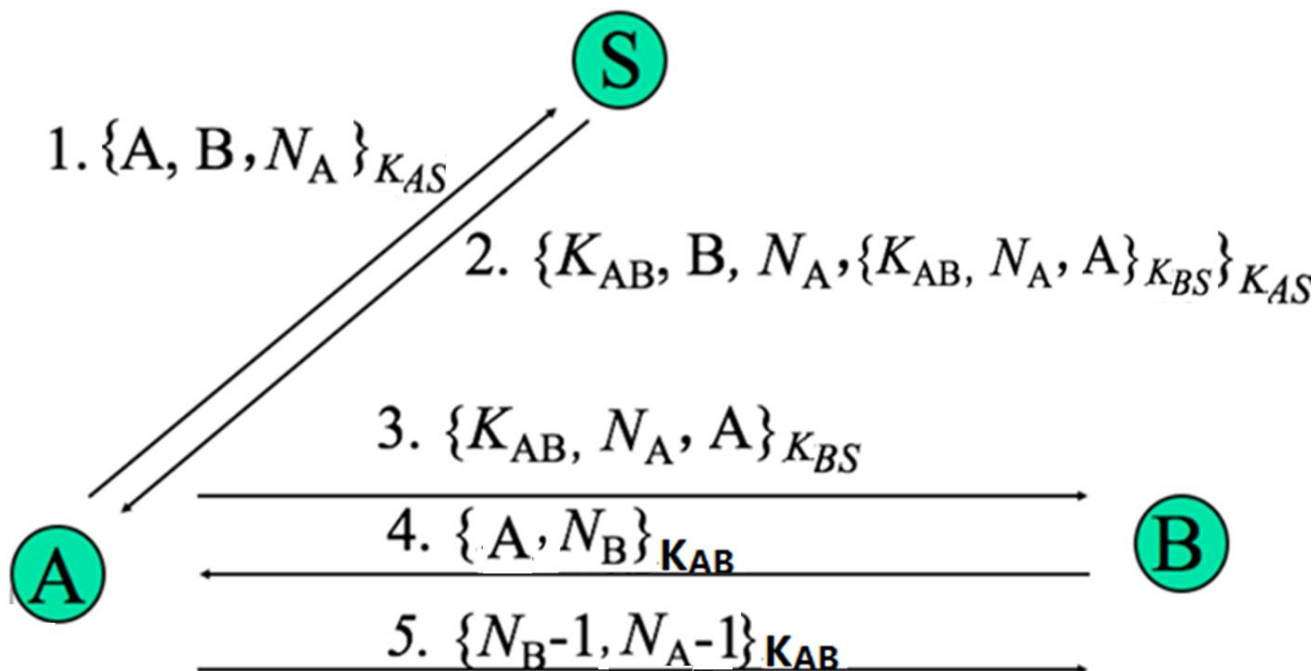


Needham-Schroeder对称密钥认证协议_v5

□改进策略：进一步将挑战 N_A 也保密



说了这么多，其实是想告诉你们
改进协议时，非常
容易按下葫芦
浮起瓢！



问题：这个改进的V5版本就安全了吗？

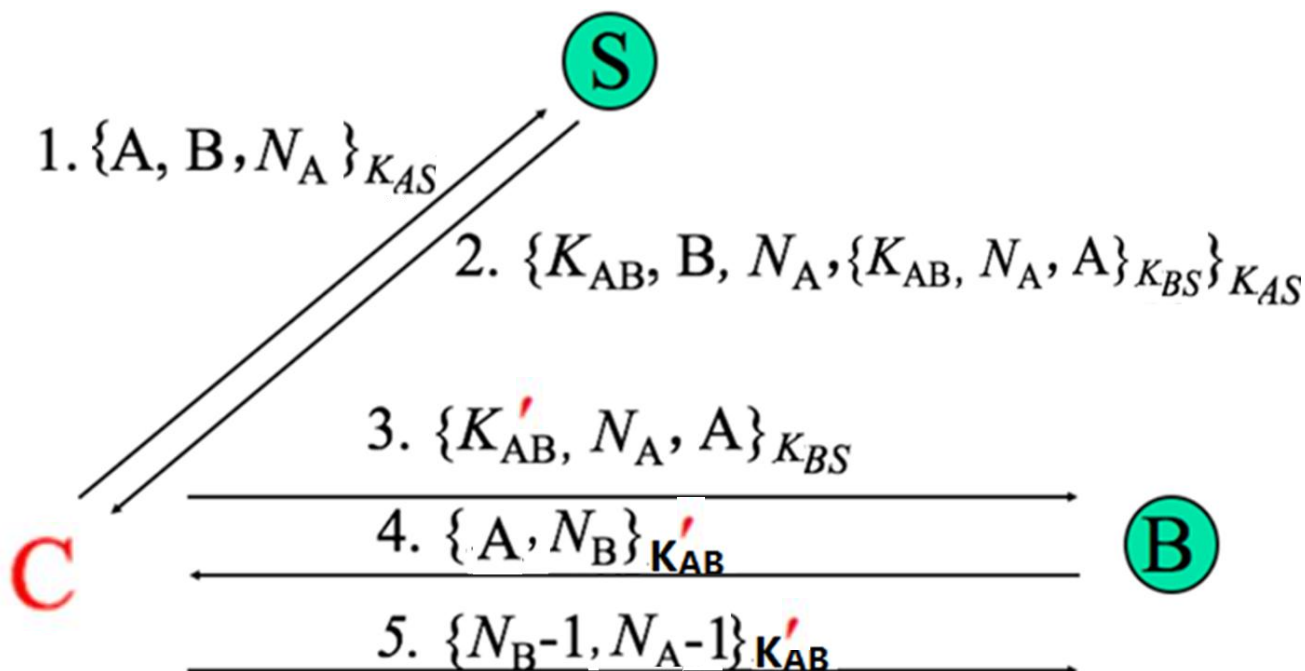
对NS_v5协议的攻击

□ 重放攻击

攻击者C的行动：1) 利用旧消息中已知的会话密钥 K'_{AB} ，

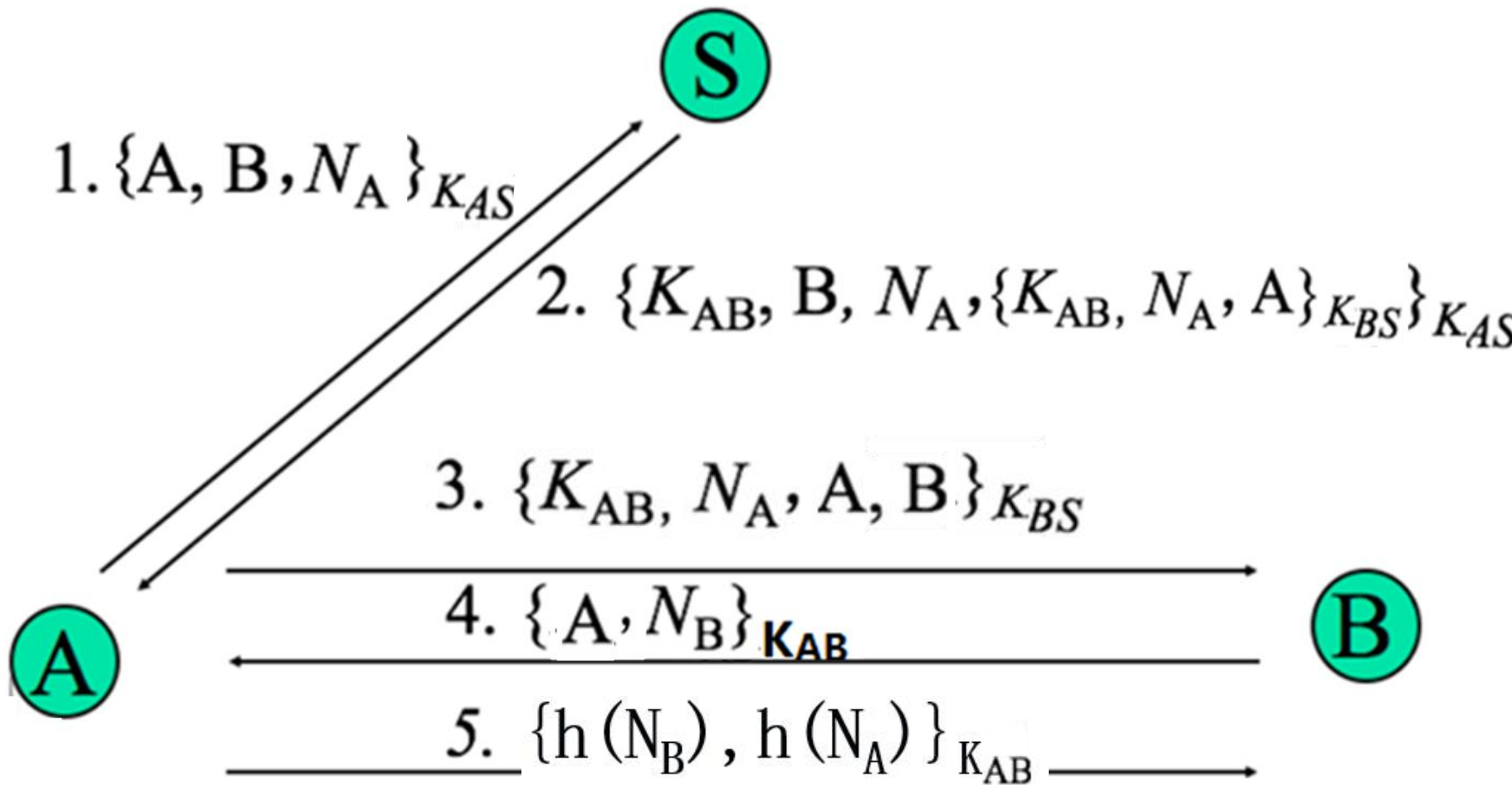
解密消息5，得到 N_A 和 N_B ；2) 重放A→B的旧消息3.

攻击结果： B认为与A通信，实际上却与C通信（因为旧消息中的会话密钥 K'_{AB} 可能已被C获得）。



Needham-Schroeder对称密钥认证协议_v6

□改进策略：令消息5为 $\{h(N_B), h(N_A)\}_{K_{AB}}$



问题：这个改进的V6版本就安全了吗？

安全协议设计和分析的困难性

□ 困难的原因

- 安全协议的功能越来越多样复杂
- 安全功能目标本身的微妙复杂性

比如，表面上十分简单的“身份认证”，实际上十分复杂微妙。

- 协议运行环境的复杂性

安全协议往往运行在开放、多方、并发、移动环境中。

- 攻击者模型的复杂性

我们必须充分考虑攻击者的能力，考虑各种各样的攻击，而如何准确地描述攻击者的能力，特别是如何形式化地对攻击者和攻击行为进行建模和形式化的分析迄今仍是公开难题。

即使国际标准也不靠谱

□ 创新的生命力在于质疑

2844

IEEE TRANSACTIONS ON INFORMATION FORENSICS AND SECURITY, VOL. 13, NO. 11, NOVEMBER 2018

Analyzing and Patching SPEKE in ISO/IEC

Feng Hao^{ID}, Roberto Metere, Siamak F. Shahandashti, and Changyu Dong^{ID}

Abstract—Simple password exponential key exchange (SPEKE) is a well-known password authenticated key exchange protocol that has been used in Blackberry phones for secure messaging and Entrust's TruePass end-to-end web products. It has also been included into international standards such as ISO/IEC 11770-4 and IEEE P1363.2. In this paper, we analyze the SPEKE protocol as specified in the ISO/IEC and IEEE standards. We identify that the protocol is vulnerable to two new attacks: an impersonation attack that allows an attacker to impersonate a user without knowing the password by launching two parallel sessions with the victim, and a key-malleability attack that allows a man-in-the-middle to manipulate the session key without being detected by the end users. Both attacks have been acknowledged by the technical committee of ISO/IEC SC 27 and ISO/IEC 11770-4 revised as a result. We propose a patched SPEKE called P-SPEKE and present a formal analysis in the Applied Pi Calculus using ProVerif to show that the proposed patch prevents both attacks. The proposed patch has been included into the latest revision of ISO/IEC 11770-4 published in 2017.

Index Terms—Password-based authenticated key exchange, formal methods, key agreement.

addressing the limitations, Jablon [25] proposed another PAKE solution called the simple password exponential key exchange (SPEKE) in 1996. SPEKE proves to be a more practical protocol than EKE since it does not have the same password leakage problem as in EKE. Although researchers raised concerns on some other aspects of SPEKE [31], [33] such as the possibility for an online attacker to test multiple passwords in one go, no major flaws have been reported. Over the years, SPEKE has been used in several commercial applications: for example, the secure messaging on Blackberry phones [11] and Entrust's TruePass end-to-end web products [16]. SPEKE has also been included into the international standards such as IEEE P1363.2 [22] and ISO/IEC 11770-4 [24].

Given the wide usage of SPEKE in practical applications and its inclusion in standards, we believe a thorough analysis of SPEKE is both necessary and important. In this paper, we revisit SPEKE and its variants specified in the original paper [25], the IEEE 1363.2 [22] and ISO/IEC 11770-4 [23] standards. We first observe that the original SPEKE protocol is subtly different from those defined in the standards. The differ-

南开大学密码学与系统安全实验室

房间：学院楼624、625、602

邮箱：wangding@nankai.edu.cn



--2026. 01

欢迎各位同学交流指正！



Woo-Lam身份认证协议

预配置：Trent作为可信第三方（TTP），Alice和Trent共享对称密钥 K_{AT} ，Bob和Trent共享对称密钥 K_{BT} ；

目标：即使Alice和Bob开始互不相识，Alice仍然能够向Bob证明自己。

- ① Alice→Bob: Alice; 【我是Alice】
- ② Bob→Alice: N_B ; 【你证明一下吧】
- ③ Alice→Bob: $\{N_B\}K_{AT}$; 【你可以去验证，Trent可以证明】
- ④ Bob→Trent: $\{Alice, \{N_B\}K_{AT}\}K_{BT}$; 【问Trent，X说她是Alice】
- ⑤ Trent→Bob: $\{N_B\}K_{BT}$; 【你如果看到NB，那就是了】

Bob使用密钥 K_{BT} 解密密文分组，如果解密后正确地返回Bob的一次性随机数，Bob就接受此次运行，否则拒绝。协议依赖TTP的可信性。

对Woo-Lam协议的攻击

Abadi和Needham对上述Woo-Lam协议的攻击（并行攻击！）

- ① Malice("Alice")→Bob: Alice; 【冒充Alice对Bob, 我是Alice】
 - 1'. Malice→Bob: Malice; 【同时执行Malice本身的认证协议——我是Malice】
- ② Bob→Malice("Alice"): N_B ; 【Bob执行Woo-Lam认证过程, 证明给我】
 - 2'. Bob→Malice: N'_B ; 【Bob执行Woo-lam认证过程, 证明给我】
- ③ Malice("Alice")→Bob: $\{N_B\}K_{MT}$; 【执行Woo-lam, 注意 N_B , 你问TTP?】
 - 3'. Malice→Bob: $\{N_B\}K_{MT}$; 【并行执行Woo-lam, 注意 N_B 不是 N'_B 】
- ④ Bob→Trent: $\{Alice, \{N_B\}K_{MT}\}K_{BT}$; 【Bob问Trent关于Alice的身份】
 - 4'. Bob→Trent: $\{Malice, \{N_B\}K_{MT}\}K_{BT}$; 【Bob问Trent关于Malice的身份】
- ⑤ Trent→Bob: $\{\text{"垃圾"}\}K_{BT}$; 【按照协议执行, N_B 被破坏了】

（产生“垃圾”是因为Trent使用 K_{AT} 对密文组 $\{N_B\}K_{MT}$ 进行了解密）

 - 5'. Trent→Bob: $\{N_B\}K_{BT}$; 【按照协议, N_B 返回了, Alice的身份被确认】
- ⑥ Bob拒绝和Malice的运行;

（因为解密后返回的是“垃圾”而不是一次性随机数 N'_B ）

 - 6'. Bob接受“和Alice的运行”, 但实际上是和Malice的运行。

（因为解密返回的 N_B 是正确的）